SHENZHEN INTERNATIONAL FINTECH COMPETITION 2026 · INTERNATIONAL TRACK · TOPIC C

SudoRoute

Security Self-Assessment

Permission tiers, controls, known risks and test evidence

Prepared by **Afia Islam** (Team Leader, Varendra University, Bangladesh) and **Md. Shamsul Alam Soron** (Lincoln University College, Malaysia)

Team SudoRoute · 20 October 2026

Live: sudoroute.onrender.com · Code: github.com/afiaislam/sudoroute · afiaislam2313@gmail.com

Summary: no AI component can move money. Every payment needs a signed proposal and a human one-time code, and the live Security Lab passes **63 of 63** checks — 57 attacks blocked, 6 legitimate actions still work. This assessment covers the sandbox prototype submitted to the 2026 Shenzhen International FinTech Competition, Topic C.

1. Permission tiers

Every tool the agent can call is registered with exactly one tier; the student chooses the session level (Read only, Advisor or Assisted payments), and the agent can never raise it (`sudoroute/security/permissions.py`).

Tier	What it allows	Who may do it	How it is enforced
T0 Read	View balances, invoices, history	Agent, always	Permission gate on every tool call
T1 Analyze	Verify invoices, compare routes, FX risk, budget	Agent in Advisor or Assisted mode	Permission gate; refusals logged
T2 Prepare	Draft an HMAC-signed payment proposal; no money moves	Agent in Assisted mode only	Gate + policy engine (10 checks); proposal signed and bound to its owner
T3 Execute	Move money	People only: the student's one-time code (or authenticator app), after the guardian's own code when family money is used	Only the confirmation endpoint with a valid signature, unexpired quote, OTP and a re-run of the policy checks; never callable from chat or by any AI role
T4 Prohibited	Pay an unregistered payee; use bank details from an invoice, e-mail or chat; unlicensed channels (hundi/hawala); crypto; raise limits or permission level; disable or edit the audit log; follow instructions inside documents; move money without confirmation and code	Nobody, in any mode	Rejected before any other check; tested in the Security Lab

The one bounded exception to “people execute” is a mandate the student signed: smart timing and instalments run by themselves only for the signed payee, invoice, amounts, price floor and deadline, re-run the policy checks at execution, and stop on cancel or kill switch.

2. Security controls

Each layer has its own control, so a failure in one does not move money.

Layer	Control
Payment integrity	HMAC-SHA256-signed proposals; 10-minute quote expiry; idempotent execution (one proposal executes once); lockout after 3 wrong codes; proposals bound to their owner
Payee	Bank details only from the verified university registry; an unknown university stays “pending verification” and receives nothing until confirmed out of band
Compliance	Policy engine with 10 checks before and again at execution: verified beneficiary, invoice authenticity, no overpayment, licensed and country-permitted channel, sanctions screening, per-transaction / 24-hour / annual limits, funds, structuring pattern, documents
AI	Planner with a fixed tool list and no execute tool; quarantined reader with no tools and a monotonic merge; hold-only auditor; number-preservation check on every model reply
Family	Guardian co-approval with a separate code; a decline is final; guardian and student kill switches; weakening a control (remove guardian, raise level) needs the password again
Second factor	SMS-style codes on the in-app phone, or an authenticator app (RFC 6238, checked against the RFC test vectors); each time-step accepted once; SMS codes stop working once an app is linked
Accounts	PBKDF2-SHA256, 310,000 iterations; password policy; 5 wrong passwords lock the account for 15 minutes; identical errors for unknown e-mails
Sessions and web	256-bit tokens in HttpOnly, SameSite=Strict cookies (Secure behind HTTPS); 30-minute idle and 12-hour absolute expiry; CSRF token and origin check on every write; strict CSP, frame blocking, nosniff; 64 KB body cap; JSON only; whitelisted static files
Audit	Append-only SHA-256 hash-chained log with PII redaction; any edit or deletion breaks the chain
Certificates	Ed25519 (RFC 8032, checked against the official test vectors); hash anchored on Bitcoin through OpenTimestamps
Secrets	API key only in `.env` (git-ignored) or the hosting dashboard; signing secret generated by the host

3. Known-risk list

Eighteen known risks, each with its mitigation, what remains, and the Security Lab test that exercises it.

#	Risk	Mitigation	Residual risk	Test
R1	Prompt injection hidden in an invoice or e-mail tells the AI to pay	Documents are untrusted data; only the quarantined reader (no tools) sees them; hidden and zero-width text flagged; “follow document instructions” is T4	A novel phrasing may evade the detector, but it still cannot create a payment	AI-01, 02, 09, 10, 11
R2	Fake invoice with a look-alike domain or	Scam shield (0–100); payee always from the registry, never	A new pattern may score REVIEW instead of BLOCK;	AI-11, CTL-04, benchmark

#	Risk	Mitigation	Residual risk	Test
	changed bank account	from the invoice	money still goes only to the registry account	
R3	Compromised or hostile AI planner tries to execute or exceed the student's mode	No execute tool; permission gate on every call; one payment tool, last	None found in testing; the model could still give poor advice, shown with verified numbers	AI-14, AI-15
R4	AI reader is manipulated into vouching for a scam	Monotonic merge: the reader can only add risk	The reader may miss a signal; the rules still apply	AI-16
R5	AI writer invents an amount or asks for the code	Number-preservation and forbidden-phrase checks; template shown instead	None found in testing	AI-17
R6	AI auditor is compromised and tries to approve or override	Only a literal hold is read; every other field ignored	A missed hold falls back to the policy engine	AI-18, PAY-14, CTL-06
R7	Jailbreak of the guardian or public assistant to leak codes, keys or prompts	Guardian assistant is read-only from facts; public assistant answers from a fixed fact sheet; rate limits	None found in testing	AI-12, AI-13
R8	Paying without consent: skip the code, skip the guardian, push a declined payment	Execution only via the confirmation endpoint with OTP; guardian code first; a decline is final	Social engineering of the code holder is outside the system	AI-04, PAY-01, 02, 03
R9	Tampering or replay of a signed payment	HMAC signature; idempotency; 10-minute expiry; owner binding	Signing secret must be kept in a KMS in production	PAY-04, 05, 06, 09, AZ-01
R10	Code guessing or reuse	Lockout after 3 wrong codes; authenticator time-steps accepted once; SMS code disabled once an app is linked	SIM-swap risk for SMS users who do not link an app	PAY-08, AU-07, AU-08
R11	Smart-timing mandate abused: replay, floor removed	Target, floor and deadline inside the signed proposal; one approval = one payment; policy re-checked at execution	Paying on the deadline can cost more than paying on day one, bounded by the signed floor	PAY-12, PAY-13, CTL-05
R12	Illegal or disallowed channel chosen because it is cheapest	Unlicensed channels are T4; country and university rules exclude channels with a reason	Country rule packs are simplified and need regulator validation	AI-06, AI-07, POL-04
R13	Access to another user's data or functions (IDOR, role abuse)	Student ID always from the session; role-separated APIs; guardians see only linked students	None found in testing	AZ-01 to AZ-08
R14	Account takeover: brute force, enumeration, CSRF, cross-origin	Lockout; identical errors; CSRF token; origin check; SameSite cookies	Phishing of the user's own password remains possible; the second factor still guards payments	AU-01 to AU-05
R15	Agent silently gains power or a control is	Level changes and guardian removal need the password; a	None found in testing	POL-01, 02, 03

#	Risk	Mitigation	Residual risk	Test
	weakened	guardian's freeze can only be released by a guardian		
R16	Evidence altered after the fact	Append-only SHA-256 hash chain	Whole-log replacement by a server operator; mitigated by anchoring hashes on Bitcoin	AI-08, POL-05
R17	Forged or inflated certificate or proof of funds	Ed25519 signatures; SudoRoute refuses to sign a claim the wallets cannot back	Certificates prove sandbox records only and are not yet recognised by lenders	PAY-07, 10, 11
R18	Web attacks: script injection, clickjacking, path traversal, malformed input	Strict CSP, frame blocking, whitelisted static files, 64 KB cap, JSON only	Minimal dependencies (standard library), so supply-chain exposure is low	WEB-01 to WEB-04

4. Test evidence

The Security Lab starts a private live copy of SudoRoute and attacks it over HTTP; the latest run passed 63 of 63 in under 3 seconds.

Group	Attacks	Result
AI (prompt injection in English, Bangla and Chinese; jailbreaks; hostile planner, reader, writer and auditor)	AI-01 to AI-18	18 blocked
Payments (co-approval, signatures, replay, expiry, code guessing, certificates, smart timing, auditor hold)	PAY-01 to PAY-14	14 blocked
Authorization (IDOR, roles, mass assignment)	AZ-01 to AZ-08	8 blocked
Authentication (brute force, enumeration, CSRF, origin, link codes, fake ratings, authenticator)	AU-01 to AU-08	8 blocked
Web (headers, path traversal, oversized and non-JSON bodies)	WEB-01 to WEB-04	4 blocked
Policy (kill switch, tier escalation, step-up, illegal cheapest route, audit tampering)	POL-01 to POL-05	5 blocked
Controls that must still succeed (two-party payment, settlement, certificate, genuine invoice, smart-timing execution, acknowledged hold)	CTL-01 to CTL-06	6 succeed

Rerun: `python scripts/security_lab.py` (report in `evidence/security_lab_report.md`) or press **Run all attacks** on `/security-lab` of the live site. The 230 automated tests include the full lab, the RFC 6238 and RFC 8032 test vectors, and the monotonic-merge test over all 16 flag combinations.

Against the real model (`scripts/eval_live_llm.py`, 20 Oct 2026, gemini-3.1-flash-lite): 24 requests in four languages including scam, stablecoin and "pay my cousin" attempts — 0 money moved, 0 leaks, the quarantined reader stayed monotonic on 100% of invoices; 23 of 24 plans correct, and the one miss failed safe (it only verified the invoice).

5. Compliance position and production requirements

SudoRoute is not a bank or a licensed money transmitter and moves no real money; in production, licensed partners would execute every payment under their own licences. Before handling real money it would need:

1. A licensed execution partner (bank, education payment platform or licensed money transfer operator) per corridor, with KYC and AML handled under that partner’s licence.
2. Country rule packs (BD, NG, IN, PK and others) validated with regulators and authorised banks.
3. Signing keys in a KMS or HSM; TOTP secrets encrypted at rest.
4. A real SMS gateway or passkeys for codes, and a production university registry with out-of-band bank verification.
5. An external penetration test and a privacy review of the data kept (masked phone numbers and PII-redacted audit logs are already in place).